

Security+ 2.2 · Phishing

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.2** —

Phishing (6:32) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Phishing is a social engineering attack delivered primarily via email. Variants include: mass phishing (broad, untargeted campaigns); spear phishing (targeted at a specific individual with personal context); whaling (spear phishing aimed at a high-profile executive, i.e., the 'whale'); vishing (voice phishing via phone call); and SMiShing (phishing via SMS). Defenses include MFA, anti-spam filtering, email sender authentication protocols (SPF, DKIM, DMARC), and security awareness training.

High-Yield Core Concepts Tested on Exam

- Whaling = phishing targeting a C-level executive (spear phishing of a 'whale')
- Vishing = phishing via VOICE call; SMiShing = phishing via SMS
- SPF/DKIM/DMARC: the email sender authentication triad
- Spear phishing = targeted attack with personal context; mass phishing = untargeted
- Defense-in-depth: MFA, anti-spam, SPF/DKIM/DMARC, user awareness

Exam Tips & Classic Scenarios

- 'C-level executives target' = whaling
- 'phishing by voice call' = vishing
- 'phishing via SMS' = SMiShing
- 'sender authentication' = SPF/DKIM/DMARC

Typical Exam Scenario: A typical exam scenario: 'an urgent email impersonating the CFO requesting a wire transfer' = whaling/BEC — not generic phishing.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.2 — Phishing)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **DKIM:** DomainKeys Identified Mail: Asymmetrically signs email headers and bodies using sender domain private keys, allowing recipient MTAs to verify email authenticity.
- **SPF:** Sender Policy Framework: DNS TXT record listing authorized sending IP addresses for a domain to prevent unauthorized email spoofing.
- **DMARC:** Domain-based Message Authentication, Reporting, and Conformance: Policy enforcing disposition (none, quarantine, reject) for emails failing SPF or DKIM checks.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A scammer sends an email IMPERSONATING the CEO and orders the finance department to make an urgent transfer. What attack is this?

- A)** BEC / CEO fraud
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. An attacker sends targeted emails to specific executives with personalized company information. What social engineering technique is this?

- A) Vishing**
- B) Whaling**
- C) Spam**
- D) Pharming**

3. An employee receives a call from someone pretending to be technical support asking for a password for a 'system update'. What technique is this?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

4. A scammer calls pretending to be IT support and creates urgency for you to give your password. The social engineering principle exploited is:

- A) Scarcity**
- B) Authority + urgency**
- C) Social proof**
- D) Reciprocity**

5. Corporate scenario (Phishing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Whaling = phishing targeting executives (spear phishing of a whale)'. What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Allow shared access among administrators using generic credentials**
- D) Implement the corresponding solution: Whaling = phishing targeting executives (spear phishing of a whale)...**

6. Corporate scenario (Phishing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Vishing = phishing by VOICE; SMiShing = by SMS'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Vishing = phishing by VOICE; SMiShing = by SMS...
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Phishing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'SPF/DKIM/DMARC: the email sender authentication trio'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: SPF/DKIM/DMARC: the email sender authentication trio...

8. Corporate scenario (Phishing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'C-level executives target' = whaling. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'C-level executives target' = whaling.

9. Corporate scenario (Phishing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'phishing by voice call' = vishing. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'phishing by voice call' = vishing.
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Phishing): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.2), an analyst evaluates the following technical requirement: 'Typical scenario: urgent email impersonating the CFO requesting a transfer' = whaling/BEC — not generic phishing. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Typical scenario: 'urgent email impersonating the CFO requesting a transfer' = whaling/BEC — not generic phishing

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — BEC / CEO fraud.

✓ **Why it is correct:** The correct answer is 'BEC / CEO fraud'. Business Email Compromise (BEC) is a category of social engineering attack where the attacker impersonates a high-level executive (such as the CEO) or a trusted business partner to induce employees to make unauthorized financial transfers or disclose confidential information. In the described scenario, the scammer sends a fraudulent email impersonating the CEO and orders an urgent transfer to the finance department. This perfectly fits the definition of BEC, which CompTIA recognizes as an attack vector based on impersonation and social engineering. The specific variant where the CEO is impersonated is called CEO fraud. Therefore, the option 'BEC / CEO fraud' best describes the attack.

✗ **Why the others are wrong:**

- *Whaling:* Whaling is a type of phishing attack specifically targeting high-level executives (such as CEOs, CFOs, etc.). The goal is to obtain confidential information or access to critical systems through fraudulent emails impersonating trusted sources. However, in the described scenario, the attacker is not targeting the CEO but impersonating them to deceive the finance department. Therefore, whaling is not the correct term, as it describes the target (the executive) and not the modus operandi of impersonating the CEO to defraud subordinates.
- *Vishing:* Vishing is the practice of social engineering conducted via phone calls (voice phishing), where the attacker impersonates a trusted entity to obtain sensitive information, such as passwords or financial data. In the scenario, the attack occurs via email, not phone. Therefore, vishing does not apply to the channel used. Additionally, vishing does not necessarily involve impersonating the CEO to order transfers, but rather fraudulent calls in general.
- *Tailgating:* Tailgating is a physical unauthorized access technique where a person follows another into a restricted area without authenticating, usually exploiting the courtesy or distraction of an authorized employee. It is unrelated to email social engineering attacks or financial fraud. The scenario describes a cyber attack based on fraudulent email, not a physical intrusion. Therefore, tailgating is completely inadequate for the situation.

2) B — Whaling.

✓ **Why it's correct:** The described technique is **Whaling**, a specialized form of spear phishing directed at high-level executives (CEOs, CFOs, directors). The attacker performs prior reconnaissance to obtain personalized information about the company and the target, such as name, position, ongoing projects, suppliers, etc., and uses it to compose a highly convincing message. The goal may be to obtain credentials, authorize fraudulent financial transfers (BEC – Business Email Compromise), or install malware. In the CompTIA Security+ (SY0-701) syllabus, whaling is explicitly listed as a type of phishing-based social engineering, distinguished by its high-profile target and high degree of personalization.

✗ **Why the others are wrong:**

- *Vishing:* Vishing (voice phishing) is the practice of deceiving victims through phone calls or voice messages, often impersonating financial institutions, technical support, or government agencies. The attacker uses verbal interaction to extract sensitive information or induce the victim to perform actions, such as providing passwords or installing remote software. In the described scenario, the vector is email directed at executives, not a phone call. Therefore, vishing does not apply because the communication medium and approach dynamics are distinct.
- *Spam:* Spam refers to the mass and indiscriminate sending of unsolicited electronic messages, usually for advertising purposes or to spread malware on a large scale. There is no personalization

or targeting of a specific audience; the goal is to reach as many recipients as possible. In this case, the emails are meticulously targeted at specific executives and contain personalized company information, which characterizes a targeted attack (spear phishing/whaling) and not spam. The lack of targeting and personalization makes spam inadequate to describe the technique.

- *Pharming*: Pharming is a technique that redirects traffic from a legitimate website to a fake site, exploiting vulnerabilities in DNS (cache poisoning) or modifying the victim's hosts file. The user believes they are accessing the correct site but is led to a fraudulent page that captures credentials or distributes malware. Unlike whaling, pharming does not involve sending personalized emails; it depends on manipulation of name resolution infrastructure or local settings. In the statement, the action is a targeted email, not a web traffic redirection, so pharming does not apply.

3) A — Vishing.

✓ **Why it's correct:** The correct answer is 'Vishing'. Vishing is a combination of 'voice' and 'phishing', i.e., social engineering conducted via telephone calls (VoIP or traditional telephone network). In the described scenario, the attacker impersonates technical support to obtain the victim's password, exactly characterizing a vishing attack. CompTIA Security+ classifies vishing as a voice-based social engineering attack, where real-time interaction increases psychological pressure and perceived credibility. The goal is to induce the victim to reveal credentials or perform harmful actions.

✗ **Why the others are wrong:**

- *Pretexting*: Pretexting is the creation of a false scenario or pretext to obtain information. Although the attacker in the statement uses a pretext (fake technical support), the primary vector is the telephone. Pretexting is a common element in many social engineering attacks, including vishing, phishing, and smishing. The alternative is incorrect because it does not specify the telephone channel, which is the defining characteristic of vishing. Technically, pretexting is the technique of building the story, while vishing is the delivery method via voice.

- *Baiting*: Baiting involves leaving a physical device (such as an infected USB drive) or a digital lure for the victim to use, exploiting curiosity. There is no relation to telephone calls or direct password requests by voice. The alternative is incorrect because it describes an attack that depends on physical action or interaction with removable media, not real-time verbal interaction.

- *Tailgating*: Tailgating is a physical unauthorized access technique where the attacker follows an authorized employee through a secure door without authenticating. It does not involve telephone, verbal social engineering, or obtaining a password. The alternative is incorrect because it belongs to the category of physical attacks, while the scenario describes a remote voice social engineering attack.

4) B — Authority + urgency.

✓ **Why it's correct:** The correct alternative is 'Authority + urgency'. Social engineering exploits cognitive biases and psychological principles to manipulate victims. In the scenario, the scammer impersonates IT support, which invokes the principle of authority (the victim tends to obey authority figures). Additionally, he creates a sense of urgency to pressure the victim to act quickly, without thinking critically. The combination of authority and urgency is a classic social engineering tactic, recognized by CompTIA. Therefore, the option 'Authority + urgency' accurately describes the principles exploited.

✗ **Why the others are wrong:**

- *Scarcity*: Scarcity is a persuasion principle that exploits the perception that resources are limited, creating a feeling that the opportunity may be lost if not acted upon immediately. In the scenario, there is no mention of scarce resources or limited offers. The scammer is not offering something in limited quantity, but rather impersonating authority and creating urgency. Therefore, scarcity is not

the applicable principle.

- *Social proof*: Social proof is the tendency for people to follow the behavior of others, assuming that actions taken by many are correct. In the described attack, there is no mention of other people doing the same or endorsing the action. The scammer does not use the idea that 'everyone is doing it' to convince the victim. Therefore, social proof is not the principle exploited.
- *Reciprocity*: Reciprocity is the principle that people feel obliged to return a favor or concession. In the scenario, the scammer does not offer anything first and then ask for the password; he simply impersonates support and creates urgency. There is no exchange of favors. Therefore, reciprocity does not apply.

5) D — Implement the corresponding solution: Whaling = phishing targeting executives (spear phishing of a whale)....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Phishing): Whaling = phishing targeting executives (spear phishing of a whale). Whaling is a highly targeted form of phishing aimed at senior executives, often using personalized and sophisticated social engineering tactics to steal sensitive information or authorize fraudulent transactions.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Vishing = phishing by VOICE; SMiShing = by SMS....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Phishing): Vishing = phishing by VOICE; SMiShing = by SMS. Vishing (voice phishing) uses phone calls to trick individuals into revealing sensitive information, while SMiShing (SMS phishing) uses text messages. Recognizing these terms is essential for identifying and mitigating social engineering attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) D — Implement the corresponding solution: SPF/DKIM/DMARC: the email sender authentication trio....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for

lesson 2.2 (Phishing): SPF/DKIM/DMARC: the email sender authentication trio. SPF (Sender Policy Framework) specifies which mail servers are authorized to send email on behalf of a domain via DNS TXT records. DKIM (DomainKeys Identified Mail) adds a cryptographic signature to outgoing messages, allowing the recipient to verify the message was sent by the domain and was not altered in transit. DMARC (Domain-based Message Authentication, Reporting, and Conformance) builds on SPF and DKIM by defining a policy for handling messages that fail authentication (none, quarantine, or reject) and provides reporting. Together, they mitigate email spoofing, phishing, and Business Email Compromise (BEC) by enabling receivers to validate the sender's authenticity.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: 'C-level executives target' = whaling..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Phishing): 'C-level executives target' = whaling. Whaling is a highly targeted phishing attack aimed at senior executives (CEO, CFO, etc.) to steal sensitive information or authorize fraudulent transactions. It is a form of spear phishing with a specific high-value target.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) B — Implement the corresponding solution: 'phishing by voice call' = vishing..

✓ **Why it is correct:** Per the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Phishing): 'phishing by voice call' = vishing. Vishing (voice phishing) is a social engineering attack in which the attacker uses a phone call — often leveraging VoIP and caller ID spoofing — to trick the victim into revealing sensitive information, credentials, or authorizing fraudulent transactions. It is a recognized phishing variant alongside smishing (SMS) and pharming.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaches compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.

- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: Typical scenario: 'urgent email impersonating the CFO requesting a transfer' = whaling/BEC — not generic phishing.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.2 (Phishing): Typical scenario: 'urgent email impersonating the CFO requesting a transfer' = whaling/BEC — not generic phishing. Whaling is a type of phishing that targets high-profile executives, and Business Email Compromise (BEC) is a sophisticated scam where attackers impersonate executives to trick employees into transferring funds or revealing sensitive information. This scenario specifically describes whaling/BEC, not generic phishing.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.